Post-mortem INC-2026-118 — Transferencias fallidas y duplicadas tras desplegar 2.3.0

Cuándo: viernes por la tarde · **Severidad:** alta (dinero de clientes) · **Formato:** sin culpables; se analizan procesos, no personas.
Línea de tiempo: despliegue antes de las 16:40 (supuesto) → **16:40** primeros 504 → **16:55** reportes de clientes desde la app → **17:20** fin de los 504.

Hallazgos

- **Pipeline:** cobertura 61 % con el umbral desactivado · usuario personal de un proveedor · artefacto SNAPSHOT · runtime con *fallback* silencioso · aprobación omitida por rama `hotfix/*` · despliegue un viernes por la tarde.
- **Configuración de prod:** URL del **core de QA** · contraseña en texto plano · timeout de 5 s · `apiId` igual al de QA · **idempotencia desactivada** · 1 réplica.
- **Operación:** 14 % de respuestas 504 · p95 del core de 9.8 s · la app reintenta ante 504 · 37 clientes reportan duplicados · 14:32 (-06:00) registrada como 08:32, no 20:32 UTC · lo detectaron los clientes, no el monitoreo.

Causa raíz

- **Técnica:** core de QA → p95 9.8 s > timeout 5 s → 504 → la app reintenta sin idempotencia → cada reintento es una transferencia nueva. *Hipótesis, a confirmar con métricas:* el core de QA, más lento, causó el p95 de 9.8 s. Un timeout de lectura no implica "no procesada".
- **Hora (bug aparte):** `hh` (12 h) en vez de `HH`, o restar el offset en vez de sumarlo; las dos hipótesis dan 08:32.
- **Sistémica:** el pipeline permitía saltarse todos los controles: no existían o se podían apagar.

Impacto

- **Clientes:** 14 % de fallas durante 40 min y 37 reportes de duplicados. Las transferencias quedaron en el core de QA, **no en el real**: la conciliación debe confirmar si hubo doble débito o transferencias mostradas como aprobadas que no existen en el core real.
- **Banco:** daño reputacional, un nuevo hallazgo de auditoría y el costo de conciliar y atender a los clientes; registros con hora corrida y contraseña del core expuesta.

Corrección inmediata

1. Congelar despliegues, volver a la versión estable anterior, rotar la contraseña de `svc_core` y revocar el usuario personal.
2. Conciliar 16:40–17:20 (core de QA contra core real), corregir, avisar a los 37 clientes y corregir la hora según la hipótesis confirmada.

Controles preventivos

Antes	Después	Dónde
Cobertura 61 %, umbral apagado	JaCoCo ≥ 80 % fijo en `verify`; falla sin reporte o con 0 pruebas	pom.xml, verificar-evidencia.sh
Usuario `jlopez.contractor`	`GITHUB_TOKEN` efímero; escritura en el registro solo al publicar	cd.yml
Artefacto SNAPSHOT	Solo tag = versión del pom, sin SNAPSHOT, desde `main`; la misma imagen por digest en todos	cd.yml
Runtime con *fallback*	Versiones exactas; si no arranca, la prueba de humo detiene el despliegue	Dockerfile, smoke-ambiente.sh
Aprobación omitida (`hotfix/*`)	Environment `prod`: revisor ≠ autor, sin bypass, solo tags	cd.yml, README
Viernes por la tarde	Prod solo de lunes a jueves en horario; emergencias con un proceso	ventana-de-cambio.sh
Core de QA en prod	En prod la app no arranca con URLs de otro ambiente; el CI valida los overlays	GuardiaAmbiente, validar-config-ambientes.sh
Contraseña en el YAML	Solo variables de entorno o Secret; el build falla si un YAML trae un secreto	ArchivosDeConfiguracionTest
Timeout < p95	Conexión 2 s, lectura 15 s; lectura vencida → `PENDIENTE_CONFIRMACION`	ClienteCore
Sin idempotencia	`X-Idempotency-Key` obligatorio, reservado en PostgreSQL; no se puede apagar	ServicioTransferencias
`apiId` de QA	`client_id` propio por ambiente; prod falla si coincide con dev o qa	kong-prod.yaml, cd.yml
Una réplica	2 réplicas de API y Kong, con PDB; el CI lo exige	overlay prod
Hora corrida	UTC con `withOffsetSameInstant` y HH; pruebas de las dos hipótesis	MapeadorCoreTest
Detección por clientes	Alertas por tasa de 504 y por p95 del core	*Propuesto*

Configuración comparada: original → corregida.